函数背景

该函数来自PyPI 后端Warehouse 的上传校验逻辑。用户发布Python 软件包时，需要上传分发文件。系统会检查文件格式、包结构和潜在安全问题。

输入与输出

- 输入：
  - `filename`：待检查文件的路径或文件名；
  - `filetype`：文件类型描述；
  - `metrics`：用于记录处理耗时等指标的对象；
  - `scan`：是否执行安全扫描。
- 输出：二元组

  ```
  (is_valid, error_message)
  ```

  。
  - `is_valid=True` 表示文件通过检查；
  - `is_valid=False` 表示检查失败；
  - `error_message` 用于说明失败原因。

必要术语

术语	含义
PyPI	Python 软件包发布与下载平台
distribution file	用于发布Python 软件包的分发文件
sdist	源码分发包
wheel / `.whl`	Python 软件包的一种分发格式
archive	压缩归档文件
compression ratio	解压后大小与压缩文件大小之间的比例
`PKG-INFO`	源码分发包中的元数据文件
`WHEEL`	wheel 包中的格式元数据文件
YARA	用于识别可疑文件特征的规则扫描机制

辅助变量与辅助函数

名称	最小说明
`zipfile.is_zipfile(...)`	判断文件是否为有效zip 格式
`tarfile.is_tarfile(...)`	判断文件是否为有效tar 格式

名称	最小说明
`_commonpath(...)`	获取多个归档成员路径的公共部分
`scanner.check_members(...)`	对归档中的文件成员执行安全扫描
`zipfiles.validate_zipfile(...)`	对zip 文件进行进一步校验
`sentry_sdk.capture_message(...)`	记录需要关注的异常情况

不需要掌握的背景

被试不需要熟悉Python 打包工具的完整规范，也不需要了解YARA 规则的具体内容。只需根据代码判断不同类型文件会进入哪些检查路径